
SESIÓN 4 DE 6 · 5 HORAS · BLOQUE 7: 2H15 · DESCANSO 30 MIN · BLOQUE 8: 2H15

LLAVE PÚBLICA Y FIRMA DIGITAL

¿CÓMO SE PRUEBA, ANTE UN JUEZ, QUE UNA OPERACIÓN LA AUTORIZÓ SU TITULAR?

SIO0010 · Técnicas Criptográficas · Especialización en Seguridad de la Información de las Organizaciones · Facultad de Ingeniería · Institución Universitaria de Envigado

SECCIÓN

01

DONDE QUEDAMOS

La pregunta que quedó abierta el martes y que hoy se responde

AGENDA DE LA SESIÓN

El martes diagnosticamos por qué el mecanismo de Coopaburrá no puede dar no repudio. Hoy vemos el que sí puede, y lo que la ley colombiana exige para que valga como prueba.

BLOQUE	MINUTOS	CONTENIDO	MODALIDAD
Bloque 7	0 – 20	Realimentación de la entrega 3	Taller
	20 – 75	Intercambio de llaves, aritmética modular, RSA y curvas elípticas	Magistral
	75 – 135	Firma digital: mecanismo, errores, rediseño de H2 y firma de software	Magistral
Descanso	30		
Bloque 8	0 – 55	Valor probatorio: artículos 11 y 28 de la Ley 527, Decreto 2364 y el hallazgo H7	Magistral
	55 – 110	Laboratorio 4, con el ejercicio en Python	Laboratorio
	110 – 135	Entrega 4, trabajo independiente y cierre	Taller

DONDE NOS QUEDAMOS EL MARTES

La conclusión del martes fue negativa: sabemos qué no sirve y por qué. Hoy toca la parte constructiva.

// LO QUE YA SABEMOS QUE NO FUNCIONA

Un resumen no autentica: cualquiera lo recalcula.

Un código de autenticación con llave compartida sí autentica, pero nunca da no repudio, porque ambas partes pueden generarlo.

Ningún ajuste de configuración arregla eso: es una propiedad del mecanismo.

// LO QUE HACE FALTA

Un mecanismo donde el secreto lo tenga **una sola parte**, y donde la verificación la pueda hacer **cualquiera**.

Eso es exactamente lo que resuelve la criptografía de llave pública, y es lo único que produce una prueba oponible ante un tercero.

REALIMENTACIÓN DE LA ENTREGA 3

Veinte minutos sobre el rediseño de contraseñas y el diagnóstico de la firma. Tres observaciones generales antes de pasar al tema de hoy.

// LA SAL DECLARADA Y LA SAL APLICADA

Los equipos que hicieron el laboratorio con cuidado encontraron que los resúmenes de la evidencia B corresponden a la contraseña sola, sin la sal que la documentación afirma.

Documentar esa discrepancia vale más que cualquier recomendación: es la diferencia entre auditar y leer manuales.

// LA MIGRACIÓN

La solución estándar es envolver: aplicar la función nueva sobre el resumen que ya está almacenado, y sustituirlo por el esquema definitivo la próxima vez que el usuario entre.

Lo que casi nadie resolvió: qué se hace con las cuentas que nunca vuelven a entrar.

SECCIÓN

02

EL PROBLEMA QUE NADIE PODÍA RESOLVER

Cómo se ponen de acuerdo en una llave dos partes que nunca se han visto

EL PROBLEMA DEL INTERCAMBIO DE LLAVES

Durante más de dos mil años, toda la criptografía tuvo el mismo talón de Aquiles: para hablar en secreto había que haber compartido antes un secreto. Y compartirlo exigía un canal seguro, que es justamente lo que no se tiene.

ESCENARIO	LLAVES NECESARIAS	OBSERVACIÓN
Dos personas	1	Trivial
Diez personas, todas con todas	45	Ya es incómodo
Cien personas	4.950	Inmanejable a mano
Los 142.000 asociados de Coopaburrá	más de diez mil millones	Imposible. Y hay que distribuirlas por un canal seguro que no existe

// POR QUÉ ESTO EXPLICA LA DECISIÓN DE COOPABURRÁ

La fábrica de software puso **una sola llave para todos** precisamente para no enfrentar este problema. La decisión es comprensible y es exactamente la equivocada: el problema tiene solución desde 1976, y la solución es el tema de hoy.

1976: LA IDEA QUE CAMBIÓ TODO

Diffie, Hellman y Merkle publican un método para que dos partes que nunca se han visto acuerden un secreto común hablando por un canal que cualquiera puede escuchar. Suena imposible y no lo es.

ACUERDO DE LLAVE SOBRE UN CANAL PÚBLICO

Ana y Beto quieren un secreto común. Todo lo que envían es público.

1. Acuerdan en público un punto de partida común.
2. Cada uno elige un número secreto y no lo dice nunca.
3. Cada uno combina el punto común con su secreto y envía el resultado.
4. Cada uno combina lo que recibió con su propio secreto.

Los dos llegan al mismo valor. Quien escuchó todo no puede llegar a él, porque le faltan los dos números secretos y deshacer la combinación es computacionalmente inviable.

ARITMÉTICA MODULAR: LA MATEMÁTICA DEL RELOJ

Toda la criptografía de llave pública se apoya en una aritmética que todos conocen sin saberlo: la del reloj, donde después de las 12 viene la 1. Es lo mínimo para que lo que sigue no parezca magia.

LA ARITMÉTICA DEL RELOJ

Módulo n : se trabaja solo con el resto de dividir por n .

$$15 \bmod 12 = 3 \quad \leftarrow \text{las 15 horas son las 3}$$

$$5^3 \bmod 23 = 125 \bmod 23 = 10$$

Potencia modular: fácil de calcular, incluso con números de 600 dígitos.

$$5^x \bmod 23 = 10 \rightarrow \text{¿cuánto vale } x? \quad (\text{es } 3)$$

Con números pequeños se prueba a mano. Con números de 2048 bits no se conoce ninguna forma eficiente de encontrar x : es el problema del logaritmo discreto.

// LA IDEA QUE HAY QUE LLEVARSE

Hay operaciones que se calculan en milisegundos en un sentido y que en el sentido contrario no terminarían antes del fin del universo. **Toda la llave pública consiste en encontrar una de esas operaciones** y darle al dueño de la llave el atajo para recorrerla al revés.

DIFFIE-HELLMAN CON NÚMEROS PEQUEÑOS

El método de 1976, con números que se pueden seguir a mano. Todo lo que aparece en la columna del medio viaja por un canal que cualquiera puede escuchar.

ANA	CANAL PÚBLICO	BETO
—	Acuerdan en público: primo $p = 23$ y base $g = 5$	—
Escoge en secreto $a = 6$	—	Escoge en secreto $b = 15$
Calcula $A = 5^6 \bmod 23 = 8$	Viajan $A = 8$ y $B = 19$	Calcula $B = 5^{15} \bmod 23 = 19$
Calcula $19^6 \bmod 23 = 2$	Nadie más puede calcular el 2	Calcula $8^{15} \bmod 23 = 2$

// QUÉ TENDRÍA QUE HACER UN ESPÍA

Ve pasar 23, 5, 8 y 19. Para llegar al secreto común necesita el 6 o el 15, es decir, resolver $5^x \bmod 23 = 8$. Con 23 se prueba a mano; **con un primo de 2048 bits, o con una curva elíptica de 256, no hay forma conocida de hacerlo.**

LO QUE ESE MÉTODO NO RESUELVE

Resuelve el acuerdo de llave, pero no dice con quién se está acordando. Y esa omisión abre un ataque que hay que conocer porque reaparece en la sesión 5.

// EL ATAQUE DEL INTERMEDIARIO

Alguien situado en medio acuerda una llave con Ana haciéndose pasar por Beto, y otra con Beto haciéndose pasar por Ana.

Descifra, lee, vuelve a cifrar y reenvía. Las dos partes creen que hablan en secreto y así es: en secreto con el atacante.

// LA PIEZA QUE FALTA

Hace falta poder verificar la identidad de la otra parte antes de confiar en la llave acordada.

Esa verificación es el trabajo de los certificados y de la infraestructura de llave pública, que es la sesión del martes.

Por ahora quédense con esto: **acordar una llave no es lo mismo que saber con quién.**

SECCIÓN

03

DOS LLAVES EN LUGAR DE UNA

Cómo funciona la criptografía asimétrica y por qué las curvas desplazaron a RSA

UNA PAREJA, DOS USOS OPUESTOS

Se generan dos llaves relacionadas matemáticamente. Lo que una hace, solo la otra lo deshace. Una se publica sin reservas; la otra no sale nunca de su dueño.

OPERACIÓN	SE USA LA LLAVE...	PARA VERIFICAR O DESCIFRAR...	SIRVE PARA
Cifrar para alguien	pública del destinatario	su llave privada	Confidencialidad: solo él puede leerlo
Firmar un documento	privada del firmante	su llave pública, que tiene cualquiera	Autenticidad y no repudio

// LA INVERSIÓN QUE HAY QUE ENTENDER HOY

Para cifrar se usa la llave **del otro**. Para firmar se usa la **propia**. Son operaciones opuestas y confundirlas es el error conceptual más común del tema. Y la segunda es la que resuelve el caso: como la privada la tiene una sola persona, solo esa persona pudo firmar.

RSA CON NÚMEROS PEQUEÑOS

El ejemplo clásico de los libros de texto, con números que caben en una calculadora. Los números reales tienen más de 600 dígitos, pero el procedimiento es exactamente este.

LA PAREJA DE LLAVES, PASO A PASO

Generar la pareja:

dos primos secretos	$p = 61, \quad q = 53$	
módulo público	$n = p \times q = 3233$	
$\phi(n) = (p-1)(q-1)$	$= 3120$	← solo lo conoce el dueño
exponente público	$e = 17$	
exponente privado	$d = 2753$	porque $17 \times 2753 = 1 + 15 \times 3120$

Cifrar $m = 65$ con la llave pública: $c = 65^{17} \bmod 3233 = 2790$

Descifrar con la llave privada: $m = 2790^{2753} \bmod 3233 = 65$

// DÓNDE ESTÁ LA SEGURIDAD

Todo es público salvo p , q y d . Quien logre factorizar 3233 en 61×53 calcula $\phi(n)$ y de ahí d , la llave privada. **Con 3233 eso toma un segundo; con un módulo de 2048 bits, nadie sabe hacerlo.** La seguridad de RSA es, exactamente, la dificultad de factorizar.

POR QUÉ ES DIFÍCIL, Y HASTA CUÁNDO

Las familias de llave pública se apoyan en problemas distintos, y todos resisten lo que se les ha lanzado con computadores clásicos. Pero un solo algoritmo, publicado por Peter Shor en 1994, los resuelve a todos.

PROBLEMA	QUIÉN SE APOYA EN ÉL	RÉCORD PÚBLICO CLÁSICO	CON UN COMPUTADOR CUÁNTICO
Factorizar	RSA	829 bits, en 2020, con unos 2.700 años-núcleo de cómputo	Lo resuelve el algoritmo de Shor
Logaritmo discreto en enteros	Diffie-Hellman clásico	795 bits, en 2019	Lo resuelve el mismo algoritmo
Logaritmo discreto en curvas	Curvas elípticas y sus firmas	Alrededor de 112 bits	También, y con menos recursos que RSA

// LA CONSECUENCIA

Duplicar el tamaño de la llave no protege contra Shor: apenas lo retrasa. **Por eso la respuesta no son llaves más grandes sino problemas matemáticos distintos**, que es exactamente lo que el NIST estandarizó en 2024. Es la sesión 6.

RSA Y LAS CURVAS ELÍPTICAS

Dos familias que resuelven lo mismo apoyándose en problemas matemáticos distintos. La diferencia práctica no está en la seguridad, sino en el tamaño y en el costo.

NIVEL DE SEGURIDAD	LLAVE RSA	LLAVE DE CURVA ELÍPTICA	OBSERVACIÓN
112 bits	2048 bits	224 bits	Mínimo aceptable hoy; en retirada
128 bits	3072 bits	256 bits	El punto de comparación habitual. Doce veces más pequeña
192 bits	7680 bits	384 bits	Entornos de alta exigencia
256 bits	15360 bits	512 bits	RSA se vuelve impracticable a este nivel

// POR QUÉ LA TABLA IMPORTA EN UNA APLICACIÓN MÓVIL

Una llave RSA de 3072 bits y una de curva elíptica de 256 ofrecen la misma resistencia, pero la segunda ocupa doce veces menos, se genera mucho más rápido y firma en una fracción del tiempo. **En un teléfono, con batería y datos limitados, esa diferencia decide el diseño.**

TODO SISTEMA REAL ES HÍBRIDO

La llave pública es entre cientos y miles de veces más lenta que la simétrica. Nadie cifra volúmenes con ella. Se usa para lo que la simétrica no puede: acordar la llave y firmar.

EL ESQUEMA HÍBRIDO, QUE ES EL ÚNICO QUE SE USA

Lo que hace cualquier conexión segura, cada vez que alguien abre el portal:

1. Llave pública → acordar una llave simétrica para esta sesión
2. Firma digital → verificar que el servidor es quien dice ser
3. AES en modo autenticado → cifrar todo el tráfico de la sesión

La parte lenta se usa una vez; la rápida hace el trabajo de verdad.

// CONEXIÓN CON LA SESIÓN 2

El punto 3 es exactamente lo que vimos el jueves pasado. Hoy estamos añadiendo los puntos 1 y 2, que son los que faltaban para que el esquema completo tenga sentido.

RSA A SECAS NO ES SEGURO: HACE FALTA EL RELLENO

Aplicar la operación matemática de RSA directamente sobre el mensaje, tal como aparece en los libros, es inseguro por dos razones que no son teóricas.

// LOS DOS PROBLEMAS

Es **determinista**: el mismo mensaje produce siempre el mismo criptograma, así que se puede adivinar por comparación cuando el espacio de mensajes es pequeño.

Es **maleable**: se puede transformar el criptograma para que el resultado descifrado cambie de forma predecible, sin conocer la llave.

// LA SOLUCIÓN Y SU HISTORIA

Antes de operar se añade un relleno con aleatoriedad y estructura verificable.

Para cifrar, el relleno moderno se llama OAEP. Para firmar, PSS.

El relleno antiguo, todavía muy presente, permitió el ataque de Bleichenbacher de 1998, que reapareció en 2017 afectando a productos de varios fabricantes.

// LA LECCIÓN QUE SE REPITE EN TODO EL MÓDULO

El algoritmo era correcto; **lo que estaba mal era cómo se usaba**. Es exactamente lo mismo que vimos con el modo del cifrado en la sesión 2 y con la sal en la sesión 3. Nunca se implementa criptografía a mano: se usa una biblioteca que ya tomó estas decisiones.

QUÉ ES UNA CURVA ELÍPTICA

No hay que saber operarla para decidir sobre ella, pero sí entender de dónde sale su fortaleza, porque es la misma idea que sostiene casi toda la criptografía moderna.

LA PUERTA DE UN SOLO SENTIDO

La curva: los puntos (x, y) que cumplen $y^2 = x^3 + a \cdot x + b$, con aritmética módulo un primo.

Sobre la curva se define una operación de SUMA entre dos puntos.

Sumar un punto consigo mismo n veces se llama multiplicarlo por n .

Llave privada = el número n , secreto

Llave pública = el punto que resulta de multiplicar el punto base por n

Multiplicar es barato. Recuperar n conociendo los dos puntos es el problema del logaritmo discreto sobre la curva, y no se conoce ninguna forma eficiente de resolverlo con un computador clásico.

// POR QUÉ IMPORTA EL ADJETIVO CLÁSICO

Esa última palabra es la que abre la sesión 6. Un computador cuántico de escala suficiente sí sabría resolver ese problema, y también el de RSA. **Todo lo de hoy tiene fecha de caducidad conocida.**

QUÉ CURVA ESCOGER Y CUÁLES EVITAR

CURVA	ORIGEN Y USO	RECOMENDACIÓN
P-256 y P-384	Estándar del NIST. Las exige la mayoría de normas sectoriales y de proveedores de certificados	Opción segura y con el respaldo normativo que una entidad vigilada necesita
Curve25519 · Ed25519	Diseño abierto, parámetros justificados públicamente, firma determinista	Preferible cuando se puede escoger: menos formas de implementarla mal
Curvas por debajo de 224 bits	Equipos antiguos y dispositivos limitados	Retirar. Ya no ofrecen margen suficiente
Curvas de parámetros sin justificar	Propuestas de fabricante o curvas propias	Evitar. Si nadie puede explicar de dónde salieron los números, no se usa

// EL ANTECEDENTE QUE EXPLICA LA ÚLTIMA FILA

En 2014 el NIST retiró un generador de números aleatorios basado en curvas elípticas después de años de sospechas de que sus constantes escondían una puerta trasera. **Desde entonces, no poder explicar de dónde salió un parámetro es motivo suficiente para descartarlo.**

CONFIDENCIALIDAD PERSISTENTE

Una propiedad que no se ve, que no cuesta nada activar y que decide qué pasa con todo el tráfico grabado si algún día se roban la llave del servidor.

// SIN ELLA

La llave de sesión se protege con la llave privada permanente del servidor.

Quien grabe el tráfico cifrado hoy y consiga esa llave privada dentro de cinco años puede descifrar, de golpe, **todo lo que grabó**.

Grabar hoy para descifrar mañana es una estrategia real, no una hipótesis.

// CON ELLA

En cada conexión se genera una pareja de llaves efímera, que se usa para acordar la llave de sesión y se descarta.

La llave permanente solo se usa para firmar, es decir, para demostrar identidad.

Si mañana se roban la llave del servidor, el tráfico de ayer sigue siendo ilegible.

// LO QUE ESTO SIGNIFICA PARA COOPABURRÁ

El portal admite todavía protocolos antiguos, según la evidencia A. Algunos de sus acuerdos de llave no tienen esta propiedad. **Cada sesión de banca en línea grabada por alguien en estos años quedaría expuesta el día que se comprometiera la llave del servidor**, que está en un equipo sin custodia desde 2022.

DÓNDE VIVE LA LLAVE PRIVADA

Toda la seguridad del esquema descansa en una sola suposición: que la llave privada la tiene una sola parte. Dónde se guarde es, por lo tanto, la decisión de diseño más importante.

DÓNDE	QUÉ GARANTIZA	USO TÍPICO
Archivo protegido con contraseña	Casi nada: se copia con el archivo	Pruebas y desarrollo, nunca producción
Almacén de llaves del sistema operativo	Queda atada a la cuenta del usuario	Estaciones de trabajo
Enclave seguro del teléfono	La llave se genera dentro y no sale nunca; el uso exige biometría	Banca móvil. Es la pieza que Coopaburrá no está usando
Token criptográfico o tarjeta	Portátil, protegida por PIN, no extraíble	Firma de personas: representante legal, revisor fiscal
Módulo de hardware dedicado	Doble control, ceremonia registrada, resistencia física certificada	Llaves de la organización y de los cajeros: el hallazgo H6

SECCIÓN

04

FIRMA DIGITAL

El único mecanismo que produce una prueba oponible ante un tercero

QUÉ PASA REALMENTE AL FIRMAR

Firmar no es cifrar el documento con la llave privada, aunque muchos manuales lo expliquen así. Son dos pasos y el primero es una función resumen, que ya conocemos.

LOS DOS PASOS DE CADA LADO

FIRMAR

1. Se calcula el resumen del documento SHA-256(documento)
2. Se opera ese resumen con la llave privada → firma

VERIFICAR

1. Se calcula de nuevo el resumen del documento recibido
2. Se opera la firma con la llave pública del firmante
3. Si ambos coinciden: el documento no cambió y lo firmó el titular

// POR QUÉ SE FIRMA EL RESUMEN Y NO EL DOCUMENTO

Por velocidad, porque la operación asimétrica es lenta y el resumen siempre mide lo mismo. Pero también por esto: **si la función resumen tiene colisiones, la firma sobre un documento vale para otro**. Por eso firmar con SHA-1 dejó de ser aceptable, y por eso la sesión del martes viene antes que esta.

QUÉ PRUEBA UNA FIRMA Y QUÉ NO

LA FIRMA PRUEBA

Que el documento no fue alterado después de firmarlo

Que quien firmó tenía la llave privada en ese momento

Que cualquiera puede verificarlo sin secretos compartidos

Que el firmante no puede negarlo de forma creíble

LA FIRMA NO PRUEBA

Cuándo se firmó. La fecha del sistema la pone quien firma y se puede cambiar

Que quien firmó fuera el titular legítimo, si la llave estaba comprometida

A quién pertenece la llave pública: eso lo dice el certificado, no la firma

Que el firmante entendiera o aceptara el contenido

// LAS DOS CARENCIAS QUE SE CUBREN DESPUÉS

La fecha se resuelve con un sello de tiempo de un tercero, que vemos en la sesión 6. La pertenencia de la llave pública se resuelve con certificados, que es la sesión del martes. **Una firma sola no basta: es una pieza de un sistema.**

EL NÚMERO QUE DEBE SER ÚNICO

Los esquemas de firma más usados necesitan, en cada firma, un número aleatorio irrepetible. Es el mismo requisito que ya vimos dos veces, y su incumplimiento es catastrófico de una forma particular.

// LO QUE PASA SI SE REPITE

Con dos firmas hechas con el mismo número, la matemática permite despejar la llave privada.

No se filtra el documento: se filtra la llave. El atacante puede firmar en nombre del titular desde ese momento y hacia atrás.

Es lo que ocurrió en el caso de la consola de videojuegos que vimos en la sesión 1.

// CÓMO SE EVITA HOY

Con un generador criptográfico correcto, como ya sabemos.

O mejor: con esquemas deterministas, que derivan ese número del propio mensaje y de la llave privada, de modo que no depende de la calidad del generador.

Es una de las razones por las que los esquemas modernos de curva elíptica son preferibles.

ECDSA Y ED25519: LAS DOS FIRMAS DE CURVA

Las dos firmas de curva más usadas difieren justo en lo de la diapositiva anterior: el número de cada firma.

CRITERIO	ECDSA	ED25519
Origen	Estándar del NIST desde 2000, curvas P-256 y P-384	De 2011; IETF en 2017; admitido por el NIST en 2023
Número por firma	Aleatorio: si el generador falla, se filtra la llave	Determinista: sale del mensaje y de la llave
Implementación	Con varias trampas conocidas; exige cuidado	Diseñada para dejar pocas formas de equivocarse
Rendimiento	Bueno	Mejor, tanto al firmar como al verificar
Dónde aparece	Certificados, canal seguro, documentos firmados	Acceso remoto, firma de software, sistemas nuevos

// PARA EL REDISEÑO DE H2

Si el teléfono y el servidor lo admiten, Ed25519 elimina de raíz el riesgo del número repetido. Si la normativa o el proveedor exigen curvas del NIST, ECDSA con número determinista, que también está estandarizado, es la alternativa.

QUÉ SE FIRMA EXACTAMENTE

La pregunta parece trivial y no lo es. La mayoría de los fraudes sobre sistemas que sí firman no rompen la firma: aprovechan que se firmó lo que no era.

EL CONTENIDO DE UNA OPERACIÓN FIRMADA

MAL: se firma "transferencia aprobada"
el servidor ejecuta la operación que tenga en sesión.
El atacante cambia la operación y la firma sigue siendo válida.

BIEN: se firma el contenido completo y sin ambigüedad:
asociado · dispositivo · cuenta destino · monto · moneda ·
fecha y hora · número único de operación

El servidor verifica la firma Y comprueba que el contenido firmado sea exactamente la operación que va a ejecutar. Las dos cosas, siempre.

// EL NÚMERO ÚNICO DE OPERACIÓN NO ES DECORACIÓN

Sin él, una operación firmada válida se puede reenviar diez veces y las diez son auténticas. **Firmar bien no impide reproducir**: hay que rechazar explícitamente lo ya visto.

LO QUE SE VE ES LO QUE SE FIRMA

Firmar el contenido completo resuelve la mitad del problema. La otra mitad es garantizar que lo que el asociado vio en la pantalla es lo mismo que el enclave firmó.

// EL ATAQUE

Un programa malicioso en el teléfono muestra «transferir 50.000 a mi hermana» y le entrega al enclave «transferir 5.000.000 a otra cuenta».

El asociado pone la huella convencido de lo que vio. La firma es válida, y el no repudio juega en su contra.

No hay criptografía rota: el engaño ocurre antes de firmar.

// LAS DEFENSAS

Confirmación protegida del sistema operativo: el monto y el destino se muestran en una pantalla que la aplicación no puede dibujar.

Confirmación por un segundo canal para montos altos o destinos nuevos.

Límites y demoras para cuentas recién inscritas: el fraude suele ir a destinos nuevos.

// POR QUÉ ESTO VA EN EL INFORME

El no repudio es un arma de doble filo: **si el esquema no garantiza lo que el asociado vio, la cooperativa termina probando contra su propio cliente una operación que él no quiso hacer.** Un juez lo va a preguntar.

CINCO FORMAS DE IMPLEMENTAR MAL UNA FIRMA

EL ERROR

POR QUÉ ROMPE TODO

Aceptar el algoritmo que el propio mensaje declara

Hubo bibliotecas que aceptaban un mensaje que decía venir sin firma y lo daban por válido. El verificador debe fijar de antemano qué algoritmo espera

Verificar la firma y no comparar el contenido

La firma es correcta, pero es la de otra operación. Es el error del que hablábamos en la diapositiva anterior

No rechazar operaciones repetidas

Una transferencia legítima reenviada sigue verificando. Hay que llevar registro de los números ya usados

Confundir firma válida con identidad probada

Una firma válida prueba que quien firmó tenía esa llave privada, no quién es. Eso lo dice el certificado

Usar la misma pareja para cifrar y para firmar

Mezcla dos usos con ciclos de vida distintos y, en algunos esquemas, permite ataques cruzados

CÓDIGO DE AUTENTICACIÓN O FIRMA: CUÁL Y CUÁNDO

No es que uno sustituya al otro. Cada uno resuelve un problema distinto y confundirlos es justamente lo que hizo la fábrica de software de Coopaburrá.

CRITERIO	CÓDIGO DE AUTENTICACIÓN	FIRMA DIGITAL
Llave	Una, compartida entre las partes	Pareja: privada del firmante, pública para todos
Quién puede verificar	Solo quien tiene la misma llave	Cualquiera, incluido un juez
No repudio	Nunca. Ambas partes pudieron generarlo	Sí, si la privada está bajo control exclusivo
Costo por operación	Muy bajo: microsegundos	Entre cien y mil veces mayor
Dónde sí conviene	Integridad entre dos sistemas propios: respaldos, colas internas, sesiones	Actos con consecuencia jurídica: transferencias, contratos, pagarés

EL REDISEÑO DE H2, PASO A PASO

01

Al activar la aplicación, el teléfono genera la pareja dentro de su enclave seguro

La llave privada no sale del chip, ni siquiera la ve la aplicación. El servidor nunca la conoce.

02

La llave pública se registra atada al asociado y a ese dispositivo

Con verificación de identidad en el enrolamiento, que es el momento crítico de todo el esquema.

03

Cada operación se firma dentro del enclave, tras autenticación biométrica

Lo firmado es el contenido completo: asociado, dispositivo, destino, monto, fecha y número único.

04

El servidor verifica con la llave pública registrada y archiva el conjunto

Firma, contenido firmado y momento, en el registro encadenado que diseñaron en la sesión 3.

// LO QUE CAMBIA RESPECTO DEL ESQUEMA ACTUAL

Hoy existe **una sola llave para 142.000 asociados y para todas las versiones desde 2023**. Con el rediseño hay 142.000 llaves privadas y ninguna está en el servidor. Un atacante que comprometa el servidor ya no puede fabricar operaciones: solo puede leer llaves públicas.

EL TELÉFONO SE PIERDE, SE CAMBIA Y SE VENDE

Aquí es donde se cae la mayoría de los diseños de esta clase. La criptografía es la parte fácil; el ciclo de vida es la que hay que resolver antes de proponerla al comité.

// LAS SITUACIONES QUE HAY QUE RESPONDER

Cambio de teléfono: hay que enrolar de nuevo, y eso exige volver a verificar identidad. ¿Por qué canal?

Pérdida o robo: hay que revocar esa llave pública de inmediato. ¿Quién puede pedirlo y con qué verificación?

Varios dispositivos por asociado: ¿se permite? ¿Cuántos? ¿Se ve la lista desde el portal?

// LA PREGUNTA QUE CASI NADIE HACE

¿Qué pasa con las operaciones que ese dispositivo firmó **antes** de ser revocado?

Siguen siendo válidas, porque la firma prueba el momento de la firma, no el de la verificación.

Por eso hace falta saber cuándo se firmó, y por eso el sello de tiempo no es opcional.

LA APLICACIÓN TAMBIÉN VA FIRMADA

La firma no es solo para documentos y operaciones. Toda aplicación que se instala en un teléfono va firmada por quien la publica, y esa firma es la que garantiza que nadie la alteró en el camino.

// QUÉ GARANTIZA

Que el paquete que se instala es exactamente el que publicó la cooperativa, sin código añadido.

Que las actualizaciones vienen del mismo editor: el teléfono rechaza una versión firmada con otra llave.

Es la defensa contra aplicaciones clonadas que circulan fuera de la tienda oficial.

// LO QUE HAY QUE CUSTODIAR

La llave de firma de la aplicación es probablemente la más valiosa de la organización: con ella se publica código a nombre de Coopaburrá en 142.000 teléfonos.

¿Quién la tiene, la fábrica de software o la cooperativa? El caso no lo dice, y es una pregunta obligatoria del informe.

// POR QUÉ LOS GOBIERNOS LA PONEN PRIMERO

En los calendarios de transición post-cuántica, **la firma de software es la primera que debe migrar**, hacia 2030, porque una firma de código falsificada compromete todos los dispositivos de una sola vez. Lo vemos en la sesión 6.

CÓMO SE VE UNA FIRMA DIGITAL EN UN PDF

Al abrir un PDF firmado, el lector muestra un panel de validación. Saber leerlo es una habilidad de auditor, porque «firma válida» puede significar cosas muy distintas.

LO QUE MUESTRA EL PANEL	QUÉ SIGNIFICA EN REALIDAD
«El documento no se ha modificado desde que se firmó»	El resumen coincide: la integridad está bien. No dice nada sobre quién firmó
«La identidad del firmante es desconocida»	La firma es matemáticamente válida, pero el certificado no llega a una raíz en la que el lector confíe
«La firma incluye un sello de tiempo incrustado»	La fecha la puso un tercero. Sin sello, la hora es la del equipo del firmante
«La firma está habilitada para validación a largo plazo»	La evidencia de verificación se guardó con el documento: es la sesión 6
«Hay cambios permitidos después de la firma»	Formularios o firmas adicionales. Hay que revisar cuáles fueron

// PARA EL HALLAZGO H7

Abran un pagaré de Coopaburrá en ese panel: no aparece ninguna firma, porque no hay ninguna. **La imagen escaneada es parte del contenido, no una firma**, y el lector no tiene nada que validar.

EL NO REPUDIO NO SE CONFIGURA: SE DISEÑA. EXIGE UNA LLAVE PRIVADA POR PERSONA.

Coopaburrá no necesita una llave mejor guardada ni un algoritmo más fuerte. Necesita que cada asociado tenga su propia llave privada, generada en su propio dispositivo, de la que el servidor solo conozca la parte pública. Solo así una operación queda atribuida a una persona y no a un programa. Eso cambia la arquitectura, no la configuración, y por eso es una decisión del comité y no del área de desarrollo.

SECCIÓN

05

VALOR PROBATORIO

Bloque 8 · La Ley 527 y las hipotecas que deben durar veinte años

QUÉ DICE LA LEY 527 DE 1999

Ustedes ya conocen el marco general de marco legal. Aquí está lo que aplica a este problema concreto: cuándo un documento electrónico y una firma electrónica tienen el mismo valor que el papel y la firma manuscrita.

CONCEPTO	QUÉ ESTABLECE	CONSECUENCIA PRÁCTICA
Mensaje de datos	La información electrónica no pierde valor probatorio por ser electrónica	Un contrato en archivo digital puede valer lo mismo que uno en papel
Equivalencia funcional	Un requisito de escrito o de firma se cumple electrónicamente si se satisfacen ciertas condiciones	Lo que importa no es el formato, sino las garantías que ofrece
Firma confiable	Debe permitir identificar al firmante y detectar cualquier alteración posterior, y estar bajo el control exclusivo de quien firma	Una imagen escaneada no cumple ninguna de las tres
Entidades de certificación	Terceros acreditados que respaldan la correspondencia entre una llave y una persona	Son quienes convierten una firma técnica en una prueba oponible

FIRMA ELECTRÓNICA NO ES FIRMA DIGITAL

La confusión entre estos dos términos es la que produce el hallazgo H7, y es una confusión que cuesta dinero cuando llega un litigio.

// FIRMA ELECTRÓNICA

Categoría amplia: cualquier método electrónico que permita identificar a una persona y manifestar su aprobación.

Incluye una clave, un código enviado al teléfono, o una imagen trazada en una tableta.

Su fuerza probatoria depende de qué tan confiable sea el método, y hay que demostrarla caso por caso.

// FIRMA DIGITAL

Un tipo específico de firma electrónica basado en criptografía de llave pública y respaldado por un certificado.

La ley le reconoce presunciones que la firma electrónica genérica no tiene.

Quien la niega tiene que probar que no fue él, y no al revés. Esa inversión es toda la diferencia.

// LA FRASE PARA EL INFORME

Coopaburrá no tiene ni siquiera una firma electrónica defendible: tiene **una imagen pegada a un PDF**, que no está bajo control exclusivo del firmante y no detecta alteraciones posteriores.

LOS CINCO ATRIBUTOS DEL ARTÍCULO 28

El artículo 28 de la Ley 527 dice cuándo una firma digital vale lo mismo que una manuscrita, y presume que quien la puso quiso obligarse. Son cinco condiciones, cada una con traducción técnica.

ATRIBUTO	TRADUCCIÓN TÉCNICA	¿LA IMAGEN DE COOPABURRÁ LO CUMPLE?
Es única a la persona que la usa	Una llave privada por persona, no compartida	No: la imagen se copia a cualquier documento
Es susceptible de ser verificada	Una llave pública certificada para verificarla	No: no hay nada que verificar
Está bajo el control exclusivo de quien la usa	La llave privada, en manos del firmante	No: la imagen la custodia la cooperativa
Está ligada al mensaje: si cambia, la firma se invalida	La firma recae sobre el resumen del documento	No: se edita el PDF y la imagen sigue ahí
Está conforme a la reglamentación	Certificado de una entidad acreditada	No

// LA PRESUNCIÓN QUE SE PIERDE

Cuando se cumplen los cinco, **la ley presume que el suscriptor quiso obligarse** y es él quien debe probar lo contrario. Con una imagen escaneada no hay presunción: es la cooperativa la que tiene que probarlo todo, veinte años después.

LA FIRMA ELECTRÓNICA CONFIABLE: DECRETO 2364 DE 2012

No todo tiene que ser firma digital. El Decreto 2364 de 2012, hoy compilado en el Decreto 1074 de 2015, reglamenta la firma electrónica y dice cuándo es confiable.

// CUÁNDO ES CONFIABLE

Los datos de creación de la firma, en el contexto en que se usan, corresponden exclusivamente al firmante.

Es posible detectar cualquier alteración no autorizada del mensaje, hecha después de firmar.

Cumplidas las dos, tiene la misma validez y efectos que la firma manuscrita.

// QUÉ SIGNIFICA PARA EL CASO

Para operaciones de la aplicación, una firma electrónica confiable puede bastar: el rediseño de H2 la cumple.

Para un pagaré hipotecario a veinte años, la firma digital acreditada da algo más: la presunción del artículo 28.

La decisión es de proporcionalidad, y hay que argumentarla en el informe.

// LA IMAGEN ESCANEADA NI SIQUIERA ES CONFIABLE

No corresponde exclusivamente al firmante, porque se copia, y no permite detectar alteraciones. **No cumple ni la exigencia más baja de la norma.**

EL HALLAZGO H7 EN DETALLE

Los créditos hipotecarios de Coopaburrá se firman capturando el trazo en una tableta, pegándolo como imagen en el PDF y archivando el archivo. Veamos qué pasa cuando eso llega a un juzgado.

PREGUNTA DEL JUEZ

LO QUE COOPABURRÁ PUEDE RESPONDER HOY

¿Cómo sabe que el documento no fue alterado después de firmarlo?

No puede saberlo. El PDF se puede editar y la imagen se mantiene igual

¿Cómo sabe que esa firma la hizo el titular?

No puede. La imagen se puede copiar de otro documento firmado por la misma persona

¿Cuándo se firmó?

Solo tiene la fecha del sistema, que la cooperativa controla

¿Quién custodia el archivo?

La propia cooperativa, que es parte interesada en el litigio

// LA MAGNITUD DEL PROBLEMA

No es un contrato: es la cartera hipotecaria completa, con documentos que deben conservar valor probatorio durante los veinte años de vigencia del crédito. Y cada mes que pasa se firman más con el mismo esquema.

LO QUE MIRA EL JUEZ: EL ARTÍCULO 11

Cuando un mensaje de datos llega a un proceso, el artículo 11 de la Ley 527 le dice al juez qué valorar, según las reglas de la sana crítica. Es la lista que un buen informe debe poder responder punto por punto.

CRITERIO DEL ARTÍCULO 11	QUÉ PREGUNTARÁ EL APODERADO	CON QUÉ SE RESPONDE
Confiabilidad en la forma como se generó, archivó o comunicó	¿Cómo sabe que el sistema funcionaba bien ese día?	Registro encadenado y controles documentados
Confiabilidad en la forma como se conservó la integridad	¿Cómo sabe que nadie lo modificó después?	Resúmenes, firma y sellos de tiempo
La forma como se identifica a su iniciador	¿Cómo sabe que fue el asociado y no otro?	Firma con llave privada individual y certificado
Cualquier otro factor pertinente	¿Quién custodió la evidencia?	Custodia por un tercero o con integridad demostrable

// CONEXIÓN CON EL CÓDIGO GENERAL DEL PROCESO

El Código General del Proceso reconoce los mensajes de datos como prueba y remite a la Ley 527 para valorarlos. **Un informe que responde estas cuatro filas es, en la práctica, la defensa técnica de la cooperativa** en cualquier reclamación.

QUÉ HARÍA FALTA PARA QUE FUERA OPONIBLE

01

Firma digital con certificado de una entidad acreditada

Que ate la llave privada a la identidad del asociado mediante un tercero independiente de la cooperativa.

02

Sello de tiempo de un tercero

Que certifique que el documento existía en ese momento, sin depender del reloj de un servidor de la cooperativa.

03

Formato de conservación a largo plazo

Los certificados vencen y los algoritmos envejecen. Existen formatos de firma diseñados para que la verificación siga siendo posible décadas después, resellando periódicamente.

04

Custodia del expediente por un tercero o con integridad demostrable

Para que la parte interesada no sea la única que tiene el documento.

// EL PUNTO TRES ES EL QUE SIEMPRE SE OLVIDA

Una firma perfectamente válida hoy puede volverse inverificable en quince años, cuando el certificado haya vencido y el algoritmo esté retirado. **Conservar la prueba es un proceso, no un archivo.** Es la puerta de entrada a la sesión 6.

QUIÉN ACREDITA A LAS ENTIDADES DE CERTIFICACIÓN

En Colombia, una entidad de certificación digital necesita acreditación para que sus certificados den las presunciones de la ley. Saber cómo se verifica evita contratar a quien no la tiene.

PREGUNTA	RESPUESTA
¿Quién acredita?	El Organismo Nacional de Acreditación de Colombia, ONAC, según el Decreto 333 de 2014
¿Qué se acredita?	Servicios concretos: emisión de certificados, estampado cronológico, archivo y conservación. No la empresa en abstracto
¿Cómo se verifica?	En el directorio público de organismos acreditados del ONAC, servicio por servicio y con su vigencia
¿Y si no está acreditada?	La firma sigue siendo electrónica, y su confiabilidad hay que probarla caso por caso

// LA PRIMERA LÍNEA DEL CONTRATO

El número de acreditación del servicio contratado, con su alcance y su vigencia. **Y una cláusula para el día en que la entidad pierda la acreditación o deje de operar:** los pagarés tienen que seguir siendo verificables durante veinte años.

QUÉ PREGUNTARLE A UNA ENTIDAD DE CERTIFICACIÓN

Este es el tipo de lista que se espera de un especialista, y la que nadie llevó a la reunión en la que Coopaburrá decidió montar su propia autoridad en 2019.

QUÉ PREGUNTAR	POR QUÉ IMPORTA
¿Está acreditada y para qué alcance exactamente?	La acreditación es lo que convierte la firma en prueba con presunciones. Sin ella se firma igual, pero hay que demostrarlo todo
¿Dónde queda la llave privada del suscriptor?	Si la custodia el proveedor, el control exclusivo del firmante se debilita, y con él el no repudio
¿Ofrece estampado cronológico y con qué fuente de tiempo?	Sin sello de tiempo de un tercero no hay forma de probar cuándo se firmó
¿Qué formatos de firma de larga duración maneja?	Es lo que permite que un pagaré firmado hoy siga siendo verificable en veinte años
¿Cuánto cuesta por certificado y por estampado, y cuánto tarda la emisión?	Con 142.000 asociados y cartera hipotecaria, el costo unitario decide la arquitectura completa

LA PREGUNTA DEL ABOGADO, RESPONDIDA

En la sesión 1 abrimos el módulo con la pregunta que el comité no supo responder. Hoy ya se puede responder completa, y conviene ver la respuesta entera de una sola vez.

LO QUE HAY QUE PROBAR	CON QUÉ SE PRUEBA	DE QUÉ SESIÓN VIENE
Que el contenido no cambió	Función resumen moderna sobre el contenido completo	Sesión 3
Que lo autorizó el titular y nadie más	Firma digital con llave privada en el enclave del dispositivo	Hoy
Que la llave es de esa persona	Certificado de una entidad de certificación acreditada	Sesión 5
Que ocurrió en ese momento	Sello de tiempo de un tercero, no el reloj propio	Sesión 6
Que el expediente no se manipuló después	Registro encadenado y custodia con integridad demostrable	Sesión 3 y hoy
Que seguirá siendo verificable en veinte años	Formato de conservación de larga duración y resellado periódico	Sesión 6

// LA CONCLUSIÓN PARA EL INFORME

Ninguna de las seis filas se resuelve sola, y **ninguna se resuelve comprando un producto**. El comité no necesita que le recomienden un algoritmo: necesita saber quién responde por cada fila.

SECCIÓN

06

LABORATORIO 4

Cincuenta y cinco minutos · Firmar, verificar y medir, con Python

LOS TRES EJERCICIOS

01 Ejercicio 1 · Generar, firmar y verificar

Generen una pareja de llaves, firmen un documento, verifiquenlo. Después cambien un solo carácter del documento y vuelvan a verificar. Documenten qué ocurre.

02 Ejercicio 2 · Medir la diferencia

Comparen tiempo de generación, tiempo de firma y tamaño de llave entre RSA y curva elíptica al mismo nivel de seguridad. Lleven los números a una tabla.

03 Ejercicio 3 · Verificar con la llave equivocada

Intenten verificar una firma válida con la llave pública de otra pareja. Expliquen qué garantiza exactamente el resultado y qué no.

// LO QUE SE ENTREGA

Una página por equipo con la tabla del ejercicio 2 y, sobre todo, la respuesta del ejercicio 3: **qué quedaría todavía sin resolver aunque la firma verifique correctamente**. Esa pregunta es el puente a la sesión del martes.

COMANDOS DE ARRANQUE

LABORATORIO 4 • PUNTO DE PARTIDA

Generar parejas de llaves

```
openssl genpkey -algorithm RSA -pkeyopt rsa_keygen_bits:3072 -out rsa.key
```

```
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-256 -out ec.key
```

```
openssl pkey -in ec.key -pubout -out ec.pub
```

Firmar y verificar

```
openssl dgst -sha256 -sign ec.key -out doc.sig documento.pdf
```

```
openssl dgst -sha256 -verify ec.pub -signature doc.sig documento.pdf
```

Comparar costos

```
openssl speed rsa3072 ecdsap256
```

LABORATORIO 4 · EL EJERCICIO EN PYTHON

Los ejercicios 1 y 2 con la librería cryptography: firmar con Ed25519, alterar el documento y comparar el costo con RSA.

```
LABORATORIO 4 · PYTHON 3 + CRYPTOGRAPHY
```

```
from cryptography.hazmat.primitives.asymmetric import ed25519, rsa
import time

privada = ed25519.Ed25519PrivateKey.generate()
firma = privada.sign(b"pagare 2026-0415 por 180.000.000")
privada.public_key().verify(firma, b"pagare 2026-0415 por 180.000.000") # correcto
privada.public_key().verify(firma, b"pagare 2026-0415 por 980.000.000") # InvalidSignature

t = time.perf_counter()
rsa.generate_private_key(public_exponent=65537, key_size=3072)
print("RSA-3072, generar:", round(time.perf_counter() - t, 2), "s")
```

```
// LO QUE VA EN EL INFORME
```

Midan también cuánto tarda generar una llave Ed25519 y firmar mil veces con cada esquema. **La tabla de tiempos es el argumento técnico para el teléfono del asociado**, y la línea que falla demuestra qué significa «ligada al mensaje» en el artículo 28.

LO QUE LLEVAMOS DE LA SESIÓN

01

La llave pública resolvió un problema de dos mil años

Acordar un secreto por un canal público, sin haberse visto antes.

02

Cifrar usa la llave del otro; firmar usa la propia

Son operaciones opuestas y confundirlas es el error conceptual más común.

03

Solo la firma digital da no repudio

Porque la llave privada la tiene una sola parte y la verificación la puede hacer cualquiera.

04

Una firma sola no basta

No prueba la fecha ni de quién es la llave. Hace falta sello de tiempo y certificado.

05

En Colombia la distinción firma electrónica y digital tiene consecuencias

Determina quién tiene que probar qué cuando hay litigio.

CUARTA PARTE DEL PRODUCTO

Se entrega al inicio de la sesión 5. En el mapa del módulo es la parte de certificados y llaves; se le añade el cierre del rediseño de la firma, que es lo que acabamos de ver.

SECCIÓN	QUÉ DEBE CONTENER
Cierre del rediseño de la firma · H2	Esquema con llave privada por dispositivo: cómo se genera, dónde vive, qué conoce el servidor, qué se firma exactamente y qué pasa cuando el asociado cambia de teléfono
Qué se conserva del esquema actual	No todo se bota. Hay usos donde un código de autenticación con llave compartida sigue siendo adecuado; digan cuáles y por qué
Plan de choque de certificados · H5	Con la evidencia del caso: qué certificados existen, quién responde por cada uno, qué se hace antes del 14 de junio y qué se hace con la autoridad interna. El martes se corrige y se afina
Custodia de las llaves de los cajeros · H6	El anexo técnico las identifica como 3DES cargadas a mano en 2019, sin rotación. Definan quién custodia, con qué doble control y con qué registro de ceremonia. Es el punto de partida de la política que se cierra en la sesión 6

// LO DE LAS HIPOTECAS NO VA EN ESTA ENTREGA

H7 quedó planteado hoy con todo lo necesario para entenderlo, pero se cierra en la parte 5, cuando tengan sello de tiempo y conservación de larga duración. **Lo que sí conviene hoy es tomar nota de la decisión difícil:** qué se hace con la cartera ya firmada con una imagen.

TRABAJO INDEPENDIENTE HASTA LA SESIÓN 5

12 h

TOTAL ENTRE
JUEVES Y MARTES

4 h

LECTURA
PREVIA

8 h

ENTREGA 4 E INFORME
DEL LABORATORIO 4

Lectura previa · 4 horas

RFC 5280

Internet X.509 PKI Certificate and CRL Profile, secciones 4.1 y 4.2: los campos del certificado y sus extensiones. 1,5 horas.

RFC 8446

TLS 1.3, sección 2: visión general del protocolo y del apretón de manos. 1,5 horas.

Decreto 333 de 2014

Entidades de certificación y su acreditación, junto con el directorio público del ONAC. Una hora.

// CONDICIÓN DE ENTRADA A LA SESIÓN 5

El martes se lee un certificado real campo por campo: se asume conocida la estructura de la sección 4.1 del RFC 5280. Las 8 horas de elaboración son la entrega 4 (7 h, en equipo) y el informe del laboratorio (1 h).

LO QUE VIENE EL MARTES

Sesión 5: certificados e infraestructura de llave pública. Es la sesión que responde la pregunta que hoy dejamos abierta dos veces.

// LA PREGUNTA QUE QUEDA ABIERTA

Una firma verifica correctamente con una llave pública. Perfecto. ¿Pero de quién es esa llave pública?

Hoy respondimos cómo se firma. El martes respondemos cómo se sabe de quién es la llave, que es el otro medio problema.

// Y EL HALLAZGO H5

La autoridad certificadora que Coopaburrá montó en 2019 para ahorrarse unos certificados.

Su llave privada está en el computador de un contratista que se fue en 2022, encendido en un rincón del centro de datos.

Y el certificado del portal vence el 14 de junio.

SIGLAS DE LA SESIÓN · 1 DE 2

ACM / IEEE

Association for Computing Machinery / Institute of Electrical and Electronics Engineers — Publicaron los artículos fundacionales de la llave pública.

AES

Advanced Encryption Standard — Cifrado simétrico; en un sistema híbrido cifra el volumen de los datos. Sesión 2.

ECDSA / EC

Elliptic Curve Digital Signature Algorithm — Firma digital sobre curvas elípticas. EC abrevia Elliptic Curve.

Ed25519

Firma de Edwards sobre la curva 25519. Determinista; estandarizada en el RFC 8032 y en FIPS 186-5.

FIPS / DSS

Federal Information Processing Standards / Digital Signature Standard — FIPS 186-5 es el estándar de firma del NIST.

IETF / RFC

Internet Engineering Task Force / Request for Comments — El organismo de estándares de internet y su serie de documentos.

NIST

National Institute of Standards and Technology — Instituto Nacional de Estándares y Tecnología de Estados Unidos.

OAEP / PSS

Optimal Asymmetric Encryption Padding / Probabilistic Signature Scheme — Los rellenos seguros de RSA, para cifrar y para firmar.

ONAC

Organismo Nacional de Acreditación de Colombia — Acredita a las entidades de certificación digital desde el Decreto 333 de 2014.

PDF

Portable Document Format — El formato en que se generan el contrato y el pagaré de las hipotecas de Coopaburrá.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

SIGLAS DE LA SESIÓN · 2 DE 2

PIN

Personal Identification Number — Número de identificación personal.

PKCS

Public-Key Cryptography Standards — Serie de estándares de llave pública; PKCS #1 define RSA y sus rellenos.

PKI / CRL

Public Key Infrastructure / Certificate Revocation List — Infraestructura de llave pública y lista de revocación. Sesión 5.

RSA

Rivest, Shamir y Adleman — Algoritmo de llave pública de 1977, basado en la dificultad de factorizar.

SHA-1 / SHA-256

Secure Hash Algorithm — Funciones resumen: la firma recae sobre el resumen del documento. Sesión 3.

TLS

Transport Layer Security — El protocolo del canal seguro. Sesión 5.

X.509

Norma de la Unión Internacional de Telecomunicaciones que define el formato de los certificados. Sesión 5.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

REFERENCIAS DE LA SESIÓN

Diffie, W. y Hellman, M. (1976).	New directions in cryptography. IEEE Transactions on Information Theory, 22(6), 644–654.	El acuerdo de llave sobre canal público
Rivest, R., Shamir, A. y Adleman, L. (1978).	A method for obtaining digital signatures and public-key cryptosystems. Communications of the ACM, 21(2), 120–126.	RSA
NIST. (2023).	FIPS 186-5: Digital Signature Standard (DSS).	RSA, ECDSA y EdDSA
IETF. (2016 y 2017).	RFC 8017: PKCS #1 v2.2 y RFC 8032: Edwards-curve digital signature algorithm (EdDSA).	Rellenos OAEP y PSS; Ed25519
Congreso de la República. (1999).	Ley 527 de 1999: mensajes de datos, comercio electrónico y firmas digitales.	Artículos 2, 5 a 13 y 28
Presidencia de la República. (2012 y 2014).	Decreto 2364 de 2012, firma electrónica, y Decreto 333 de 2014, entidades de certificación.	Firma electrónica confiable y acreditación ante el ONAC
Katz, J. y Lindell, Y. (2020).	Introduction to modern cryptography (3. ^a ed.). CRC Press.	Teoría de números, llave pública y firmas digitales

// ACCESO A LAS FUENTES

Las normas colombianas se consultan en el Sistema Único de Información Normativa. Los RFC y las publicaciones del NIST son de acceso libre; los artículos, en las bases de datos de la Institución.